

Cybersecurity Risk Assessment

Puraconnect

Perth, Western Australia

Aryan Chavan

Cybersecurity Student

Contents

Cybersecurity Risk Assessment	1
Puraconnect	1
Deliverable 1.....	3
Executive Summary	3
The Assignment.....	3
Key findings.....	3
Highest risk	3
Recommended fixes	4
Deliverable 2 – Asset Register	4
Deliverable 3 threat assessment	6
Deliverable 4 – Vulnerability assessment	8
Phishing.....	8
Ransomware	8
Insider threat.....	8
Credential theft	8
Supply chain and third-party attack	9
Business email compromise	9
OT network compromise	9
Unpatched software exploitation	9
DDoS.....	9
Data breach	9
Privileged access abuse.....	10
End of life infrastructure.....	10
Deliverable 5 – Risk Register	10
Deliverable 6 – Risk matrix	12
Deliverable 7 – Control Recommendations	13
Deliverable 8 – Framework Mapping	19

Deliverable 1

Executive Summary

Puraconnect is an energy company in Australia that supplies natural gas to homes, mining sites, factories and government buildings across Australia and the company runs two separate technology environments, one for office staff and one for the people who manage gas operations on the ground. In total Puraconnect has about 3000 employees who use these systems everyday

The Assignment

This project looks at where the company stands and what needs to be fixed, the project looks at both IT systems like email, sharepoint, and the customer database, and OT systems such as the SCADA server and pipeline controllers, it also covers how staff access the system remotely, how contractors are managed, and whether current controls are actually doing their job. The review shows the findings from an internal audit and the companies incident history.

Key findings

The internal audit showed seven issues that shows concerning issues for Puraconnect:

1. No MFA – Each account only has a username and password, no extra layer of protection such as the Microsoft authentication.
2. No security training – Staff have not been given basic cyber security training meaning they are not prepared to spot phishing emails or other basic scams.
3. Servers not patched for six months – multiple security weaknesses are just left vulnerable
4. Contractors can access operational systems but nobody has checked whether or not they should have access to them.
5. No Security Information Event Management (SIEM) – logs are being collected but no one is looking at them to see what's up
6. No privileged access management (PAM) solution – remote engineers log into operational systems through VPN with no extra checks
7. Old network gear meaning they might stop getting new security updates

Highest risk

Based on the key findings there are some risks which can cause serious harm such as:

- Ransomware shutting down gas operations and can also cause massive financial/reputational loss.
- Phishing email can easily cause loss of account because there is no extra level of MFA protection
- Exploiting the unpatched server to get into the network
- Some contractor getting into the system they aren't meant to be in
- Breach going undetected because logs existed but no one was watching them

Recommended fixes

1. Turn on MFA across all systems
2. Patch the servers
3. Make all staff do basic cybersecurity courses so they can successfully identify phishing and other attack types
4. Check which employee has access to what and avoid giving someone too much access
5. Get a SIEM in place so they security team can check what is going on
6. Put a PAM solution on remote and admin access to OT systems
7. Check the contractors before giving them access to operational systems

Deliverable 2 – Asset Register

The table below shows the main assets identified across Puraconnect's IT and OT environments where each one has been rated based on importance.

ID	Asset	Environment	Importance	Why It Matters
A01	SCADA Servers	OT	Critical	Controls gas processing and pipeline operations in real time
A02	Customer Database	IT	Critical	Holds personal and billing details for all residential and commercial customers

ID	Asset	Environment	Importance	Why It Matters
A03	Financial Systems	IT	Critical	Handles invoicing, payroll processing, and financial reporting
A04	PLC Controllers	OT	Critical	Physical devices that open/close valves and manage pressure across the pipeline
A05	Control Room Systems	OT	Critical	Central monitoring point for all field operations — if this goes down, operators lose visibility
A06	Engineering Workstations	OT	High	Used by operators to configure and interact with OT systems
A07	Microsoft 365 / Outlook Email	IT	High	Main communication tool for the business — commonly targeted by phishing and BEC attacks
A08	VPN Gateway	IT/OT	High	The entry point for anyone accessing systems remotely
A09	HR System	IT	High	Contains staff records and personal information
A10	Payroll System	IT	High	Processes salaries — a common target for financial fraud
A11	Remote Monitoring Sensors	OT	High	Field devices at remote sites that feed data back to the control room
A12	SharePoint / OneDrive	IT	Medium	Where the company stores its documents and internal procedures

ID	Asset	Environment	Importance	Why It Matters
A13	Corporate Laptops	IT	Medium	The devices used by around 500 office staff every day
A14	Site Communications Equipment	OT	Medium	Network gear at operational sites — some of it is getting old

Deliverable 3 threat assessment

These are the most relevant threats to Purconnect because of its size, industry and current security setup, the likelihood ratings reflect how probable each threat is right now.

ID	Threat	Source	Likelihood	What It Means for PURACONNECT
T01	Phishing	External	Likely	Attackers send fake emails to trick staff into handing over passwords or clicking on malware. PURACONNECT has already seen this happen (Incident A).
T02	Ransomware	External	Likely	Malicious software that locks up systems and demands payment to unlock them. A competitor was hit by this recently and it knocked out operations for days (Incident C).
T03	Insider Threat	Internal	Possible	A current or former employee (or contractor) deliberately misuses their access. The dormant contractor account in Incident B is a good example of how this can happen.
T04	Credential Theft	External/Internal	Likely	Someone steals login details — usually through phishing or by trying common passwords. Without MFA, stolen credentials basically hand over the keys.
T05	Supply Chain Attack	External	Possible	An attacker gets into PURACONNECT's systems by compromising a vendor or contractor

ID	Threat	Source	Likelihood	What It Means for PURACONNECT
				first. Since contractors currently have OT access with no security checks, this is a real concern.
T06	Business Email Compromise	External	Possible	An attacker pretends to be a senior manager or supplier via email, usually to get someone to approve a fake payment. These attacks are surprisingly effective.
T07	OT Network Compromise	External	Possible	A targeted attack on the systems that actually run gas operations — SCADA, PLCs, and control systems. The consequences could go beyond data loss into physical damage or safety risks.
T08	Unpatched Software Exploitation	External	Likely	Attackers scan for servers running software with known vulnerabilities. PURACONNECT has not patched for over six months, which makes this very achievable for an attacker.
T09	Denial of Service	External	Unlikely	Flooding the network with traffic to knock services offline. Less targeted than other threats but still possible, especially against older infrastructure.
T10	Data Breach	External/Internal	Possible	Sensitive data — customer records, financial information, staff details — being accessed or copied without authorisation.
T11	Privileged Access Abuse	Internal/External	Possible	Someone with admin or remote access rights using those rights to do things they should not. With no PAM solution, there is no oversight of who is doing what with high-level access.
T12	End-of-Life Infrastructure Exploitation	External	Possible	Old network gear that no longer receives security updates becomes an easy target. Several

ID	Threat	Source	Likelihood	What It Means for PURACONNECT
				PURACONNECT sites are getting close to this point.

Deliverable 4 – Vulnerability assessment

For each threat, there were the following weaknesses in Puraconnect's current environment which are the specific gaps that make each threat more likely to succeed.

Phishing

- No MFA — if someone clicks a link and types in their password, the attacker is straight in
- Staff have not had security training in over two years, so many probably would not recognise a well-crafted phishing email
- Email filtering may not be strong enough to catch spoofed or lookalike domains
- Incident A already showed us this is an active threat against PURACONNECT

Ransomware

- No SIEM means ransomware activity could go unnoticed until it is too late
- Unpatched servers give attackers a way in before ransomware is even deployed
- Backups have not been verified — if they exist, no one has tested whether they actually work
- IT and OT networks may not be properly separated, which means ransomware could spread from office systems into gas operations

Insider threat

- Incident B showed a contractor account stayed active for three months after the contract ended
- There is no formal process for revoking access when someone leaves or finishes a contract
- Staff likely have broader access than they actually need for their jobs
- Logs are collected but rarely reviewed, so suspicious behaviour would probably go unnoticed

Credential theft

- No MFA anywhere in the organisation — a stolen password is all an attacker needs
- No confirmed password policy requiring strong or regularly changed passwords
- No monitoring for failed login attempts or unusual access patterns
- Phishing exposure makes credential theft very easy to pull off

Supply chain and third-party attack

- Contractors get access to OT systems, but nobody has assessed whether their own security is up to scratch
- No security requirements are written into vendor contracts
- Incident B (dormant contractor account) shows the access lifecycle is not being managed
- No visibility into what contractors actually do when they are connected

Business email compromise

- If an executive email account gets taken over (easy without MFA), it can be used to authorise fake payments
- Staff have not been trained to verify unusual payment requests
- Weak email authentication settings make it easier for attackers to spoof PURACONNECT's domain

OT network compromise

- Remote engineers access OT systems through VPN with no privileged access management — no session recording, no time limits
- Contractors have direct OT access without being security assessed
- Some site network equipment is old and may not support modern security controls
- No SIEM means unusual activity in OT would likely go undetected

Unpatched software exploitation

- Servers have not been patched in over six months — meaning known, publicly documented vulnerabilities are sitting open
- No vulnerability scanning programme to identify what is at risk
- No formal patch management process with defined timelines
- End-of-life equipment cannot be patched at all, even if the team wanted to

DDoS

- Older network gear at some sites may not handle traffic spikes well
- No DDoS protection service confirmed
- Some sites may have single points of failure in their communications

Data breach

- No DLP controls — sensitive data can leave the organisation without anyone noticing
- Customer and financial data is probably accessible to more people than necessary
- No monitoring of who is accessing the customer database or how much data they are pulling
- Unpatched systems could allow unauthorised access to these databases directly

Privileged access abuse

- No PAM solution — admin passwords are not vaulted, rotated, or monitored
- Remote VPN sessions into OT are not recorded and have no timeout controls
- No dual-authorisation for high-risk changes to operational systems

End of life infrastructure

- Several operational sites have network equipment that is close to or at end-of-life
- Vendor support ending means no more security patches — vulnerabilities will accumulate
- No confirmed replacement plan or timeline
- Limited network monitoring means issues with this equipment may not be spotted quickly

Deliverable 5 – Risk Register

Each risk has its own score which is done by multiplying the likelihood by the impact which gives a final score. Both likelihood and impact are numbers between 1 and 5.

ID	Risk	Likelihood (1-5)	Impact (1-5)	Score	Rating	Assets Affected
R01	Phishing causes account takeover because there is no MFA to stop it	4	5	20	Critical	All IT systems, user accounts
R02	Ransomware encrypts critical systems and shuts down gas operations	4	5	20	Critical	SCADA, servers, operations
R03	Unpatched servers are exploited to gain a foothold in the network	4	5	20	Critical	All servers and workstations

ID	Risk	Likelihood (1-5)	Impact (1-5)	Score	Rating	Assets Affected
R04	A dormant or contractor account is used to access OT systems	4	4	16	Critical	OT systems, SCADA, PLCs
R05	An insider deliberately steals or exposes sensitive data	3	5	15	High	Customer DB, financial systems
R06	OT systems are compromised, causing operational disruption or a safety incident	3	5	15	High	SCADA, PLCs, control room
R07	Privileged VPN access to OT is abused with no monitoring in place	3	5	15	High	OT systems, VPN gateway
R08	A contractor or vendor is compromised and used as a way into PURACONNECT	3	4	12	High	OT systems, SCADA
R09	Business email compromise leads to an authorised but fraudulent payment	3	4	12	High	Financial systems, email

ID	Risk	Likelihood (1-5)	Impact (1-5)	Score	Rating	Assets Affected
R10	Customer or financial data is accessed or exfiltrated without detection	3	4	12	High	Customer DB, HR, payroll
R11	End-of-life network gear at a site is exploited, disrupting operations	3	3	9	High	Site comms, remote sensors
R12	Denial of service knocks out communications at an operational site	2	4	8	Medium	IT/OT communications
R13	A breach goes undetected for weeks because nobody is watching the logs	4	4	16	Critical	All systems
R14	Untrained staff are manipulated into bypassing security controls	4	4	16	Critical	All systems, user accounts

Deliverable 6 – Risk matrix

The matrix below shows all 14 risks by likelihood and impact where the risk IDs shown in each cell tell us where each risk sits and which risks are at that score.

	Likelihood 1	Likelihood 2	Likelihood 3	Likelihood 4	Likelihood 5
Impact 5	5 Medium	10 High	15 High R05, R06, R07	20 Critical R01, R02, R03	25 Critical
Impact 4	4 Medium	8 Medium R12	12 High R08, R09, R10	16 Critical R04, R13, R14	20 Critical
Impact 3	3 Low	6 Medium	9 High R11	12 High	15 High
Impact 2	2 Low	4 Medium	6 Medium	8 Medium	10 High
Impact 1	1 Low	2 Low	3 Low	4 Medium	5 Medium

Legend:

Critical (16–25)	High (9–15)	Medium (4–8)	Low (1–3)
------------------	-------------	--------------	-----------

Deliverable 7 – Control Recommendations

The following controls are recommended for every High and Critical risk. Rather than listing generic best practices, each recommendation is tied directly to what is missing or broken in PURACONNECT's current environment.

R01 / R14	Critical	Phishing and Social Engineering
Control	What to Do and Why	

Turn on MFA everywhere	This is the most important thing PURACONNECT can do right now because even if the attacker manages to figure out the password they still wouldn't be able to access the system because of MFA. MFA should mainly be used in Microsoft 365, VPN, email and financial systems.
Run security awareness training	Get all 3000 staff a proper training session which includes realistic phishing examples and follow up every year
Improve email filtering	Authenticate emails using the three protocols, SPF, DKIM and DMARC so that it is harder to fake Puraconnect email address.

R02	Critical	Ransomware Attack
Control	What to Do and Why	
Set up backups	Make sure back ups are set up properly, this can be done by using the 3-2-1 rule. The 3-2-1 rule is to have three different copies, two different media and one copy kept off the site so ransomware won't	
Get the patching done	Patch all overdue servers as soon as possible. Anything internet-facing should be prioritised. Then establish a monthly patch cycle going forward.	
Separate IT and OT networks	Office systems and operational systems should not be freely talking to each other. A ransomware attack that starts in email should not be able to reach SCADA.	
Lock down what software can run	Application allowlisting on servers and essential workstations ensures that only authorized software can run — preventing ransomware from executing even if it reaches a device.	
Build a response plan	Create a ransomware guide that outlines specific actions for staff, the contacts to reach out to, and the communication	

	methods to use in such an event. Rehearse it at least once annually.
--	--

R03	Critical	Unpatched Software Exploitation
Control		What to Do and Why
Patch the critical gaps immediately		All the required patches should be applied in 48-72 hours and everything that has not been patched should be audited starting with the internet facing systems and everything connected to OT.
Get vulnerability scanning in place		Use tools like Qualys and Tenable which allows vulnerability scanning and can scan for known vulnerabilities so this way the team knows what to fix, also run scans once every month to stay up to date and make sure there are no vulnerabilities.
Write a patch management policy		Define how quickly different types of patches need to be applied and who is responsible. Make exceptions go through a formal approval process.
Plan for end-of-life systems		Create a list of what is currently running on unsupported systems and build a plan to replace all the old unsupported systems withing the next 10-12 months.

R04 / R05 / R13	Critical/High	Orphaned Accounts, Insider Threat, and Unmonitored Logs
Control		What to Do and Why
Do an access review right now		Look at every active account in IT and OT. Disable anything that belongs to someone who has left, finished a contract, or changed roles. This is one of the quickest wins available.
Fix the offboarding process		Whenever someone leaves — whether they are staff or a contractor — their accounts should be disabled on their last

	day. This needs to be a formal step with someone accountable for it.
Limit access to what people actually need	Not everyone needs access to everything. Use least privilege and give each employee only what they need and no extra features.
Review access regularly	Every quarter, managers should confirm that their team still needs the access they have. This catches things that slip through offboarding.
Get a SIEM and actually use it	Set up a SIEM and use it to collect logs and set up alerts for unusual activity such as, weird login times, bulk data downloads or suspicious network traffic.

R06 / R07	Critical	OT Network Compromise and Privileged Access Abuse
Control	What to Do and Why	
Deploy a Privileged Access Management solution	Set up a PAM tool which monitors an organisations most critical IT accounts and data, PAM tool also vaults records privileged sessions, vaults admin passwords and can limit access to specific windows of time.	
Properly segment the OT network	The OT environment should be isolated from the IT network with strict firewall rules. Only specific, authorised traffic should be allowed to cross the boundary.	
Tighten up VPN access	VPN should require MFA and certificate-based authentication. Access should be restricted to named individuals and reviewed regularly. Sessions should have time limits.	
Know what OT assets you have	Maintain an up-to-date list of all OT devices. Apply security hardening guidelines to each one based on its function and exposure.	

R08	High	Third-Party and Supply Chain Risk
Control	What to Do and Why	
Assess vendors before giving them access	Before any contractor or vendor gets access to PURACONNECT systems, they should complete a security questionnaire. Higher-risk vendors should be assessed more thoroughly.	
Put security requirements in contracts	All the contracts which talk about involving system access should include sections around the cybersecurity standards, right to audit and incident reporting.	
Give contractors limited, time-boxed access	Contractors should get unique credentials, access only to what they need, and that access should automatically expire when the contract ends.	

R09	High	Business Email Compromise
Control	What to Do and Why	
MFA on all email accounts	This is covered under R01, but worth repeating — an MFA-protected email account is much harder to take over and use for BEC.	
Require dual approval for payments	Any payment above a set threshold should need two people to approve it. Changes to supplier bank details should always be verified via a phone call to a known number.	
Train staff to spot BEC	Include business email compromise examples in awareness training. Staff should know that an urgent email from the CEO asking to transfer money is a red flag.	

R10	High	Data Breach and Exfiltration
------------	-------------	-------------------------------------

Control	What to Do and Why
Implement data loss prevention controls	DLP tools can detect and block large transfers of sensitive data — whether someone is emailing it out, uploading it to a personal cloud drive, or copying it to USB.
Monitor database access	Set up logging and alerts on the customer database and financial systems. Flag anything unusual — like someone downloading thousands of records at 2am.
Restrict access to sensitive data	Customer records and financial data should only be accessible to people with a genuine business need. Review and tighten this access now.

Deliverable 8 – Framework Mapping

ACSC Essential Eight

The table below maps PURACONNECT's recommended controls to the ACSC Essential Eight. The goal should be to reach at least Maturity Level 2 across all eight strategies, which means controls are consistently applied and tested — not just documented.

Essential Eight Strategy	Priority	What PURACONNECT Should Do
Patch Applications	Critical	Address the six-month patching backlog immediately. Internet-facing apps patched within 48 hrs, others within two weeks. (R03, R08, R12)
Patch Operating Systems	Critical	Same priority as application patching — OS vulnerabilities are commonly exploited for initial access. (R03, R11)
Multi-Factor Authentication	Critical	Deploy MFA across all IT and OT access points. This is the single biggest gap in PURACONNECT's current security posture. (R01, R04, R07, R09)
Restrict Administrative Privileges	High	Apply least privilege, remove unnecessary admin accounts, and deploy a PAM solution for all privileged and remote access. (R04, R05, R07, R11)
Application Control	Medium	Implement allowlisting on servers and workstations to prevent malicious code from running. Particularly relevant for ransomware prevention. (R02, R03)
Configure Microsoft Office Macro Settings	Medium	Disable macros from internet-sourced files. Only allow signed macros where there is a genuine business need. (R01, R02)
User Application Hardening	Medium	Disable browser plugins that are not needed. This reduces the attack surface available to phishing and drive-by threats. (R01, R02)

Essential Eight Strategy	Priority	What PURACONNECT Should Do
Regular Backups	Critical	Implement the 3-2-1 backup strategy with at least one offline or immutable copy. Test restores quarterly. (R02, R06)

NIST Cybersecurity Framework (CSF 2.0)

The NIST CSF is a comprehensive guidance and best practice that private sector organisations can follow to improve information security and cybersecurity risk management. It is flexible enough to integrate with the existing security processes within any organisations in any industry. NIST CSF has different functions and categories which are to: identify, protect, detect, respond and recover.

NIST CSF Function	Categories Addressed	What This Means for Puraconnect
Identify	Asset Management, Risk Assessment, Supply Chain Risk	This means Puraconnect will have to build the asset register and maintain it, they would have to perform vendor risk assessments and formalise the risk register, this way they would know what they have and how to protect it.
Protect	Identity Management, Awareness Training, Data Security, Platform Security	Set up MFA, train all staff, use least privilege and avoid giving someone excessive privilege if they don't need it, separate the two environments and use PAM for the privileged access.
Detect	Continuous Monitoring, Anomaly Detection	Implement a SIEM system to monitor the logs, scan for vulnerabilities and set up detection for suspicious OT abnormalities

NIST CSF Function	Categories Addressed	What This Means for Puraconnect
Respond	Incident Management, Analysis, Containment	Develop and test incident response plan and have a ransomware plan so staff know what to do if something goes wrong and who to call.
Recover	Incident Recovery, Business Continuity	Test and make sure backups work and business continuity features and define how quickly each system needs to be restored. Run reviews after the incident to see what happened and how it can be prevented.

